Revalidación posterior a correcciones

OWASP ZAP Baseline y Nmap se ejecutaron nuevamente el 21/10/2026 contra el contenedor reconstruido desde el árbol de trabajo del proyecto. La verificación previa confirmó CSP, anti-clickjacking, nosniff, políticas cross-origin, Permissions-Policy y caché diferenciada.

14	4	0	63
reglas con alerta iniciales	reglas con alerta posteriores	fallos de política	controles aprobados

Controles corregidos

Hallazgo inicial	Tratamiento comprobado	Estado
CSP y anti-clickjacking	Content-Security-Policy con frame-ancestors y X-Frame-Options: DENY.	Cerrado
Script externo sin integridad	Lucide fue sustituido por iconos SVG locales.	Cerrado
Credenciales en URL	Los tres formularios declaran POST; no aparecieron query strings con claves.	Cerrado
nosniff y políticas del navegador	Se añadieron X-Content-Type-Options, COOP, COEP, CORP y Permissions-Policy.	Cerrado
Divulgación tecnológica	X-Powered-By se elimina y Nmap informa Apache httpd sin versión.	Cerrado
JavaScript de terceros	No quedan scripts externos en el portal revisado.	Cerrado

Decisión posterior

Los hallazgos prioritarios P1 del baseline inicial quedaron cerrados. El resultado posterior fue 0 FAIL, 4 WARN y 63 PASS. Las advertencias restantes se sometieron a triage y no muestran una vía de explotación confirmada en el alcance pasivo y no autenticado ejecutado.

Triage de advertencias restantes

El JSON posterior contiene 5 entradas, 12 instancias y cuatro identificadores de regla únicos. La diferencia se debe a que ZAP representa dos decisiones de caché bajo el mismo identificador 10049.

Regla	Evidencia posterior	Clasificación del equipo
10202 - Ausencia de token anti-CSRF	3 formularios de login/registro.	No aplicable al flujo revisado: la API no autentica con cookies, exige JSON y usa token Bearer en sessionStorage. Los formularios son una defensa POST si falla JavaScript.
10027 - Comentarios sospechosos	2 instancias en api.js; evidencia: 'etira del navegador...'.	Falso positivo lingüístico por la palabra 'Retira'; no contiene secretos, tareas pendientes ni información operativa.
10109 - Aplicación web moderna	1 señal por scripts del login.	Informativa. Justifica Client Spider para ampliar cobertura; no requiere corrección.
10049 - Caché	5 respuestas no almacenables y 1 CSS cacheable.	Comportamiento esperado: HTML y errores usan no-store; CSS público usa max-age=3600 y no contiene datos personales.

Nmap posterior

Objetivo	Resultado	Lectura
host.docker.internal:8000	open - http - Apache httpd	Único puerto incluido en el alcance; la versión 2.4.68/2.4.69 ya no se divulga.

Límite que permanece

Esta revalidación confirma el baseline público y el reconocimiento del puerto 8000. No sustituye una prueba autenticada del panel, Client Spider, auditoría específica de la API ni pruebas activas de lógica de negocio. Esas actividades deben mantenerse separadas y ejecutarse solo con cuentas y datos de prueba.

Evidencia posterior

Figura 4. Resumen final de OWASP ZAP: 0 FAIL, 4 WARN y 63 PASS.

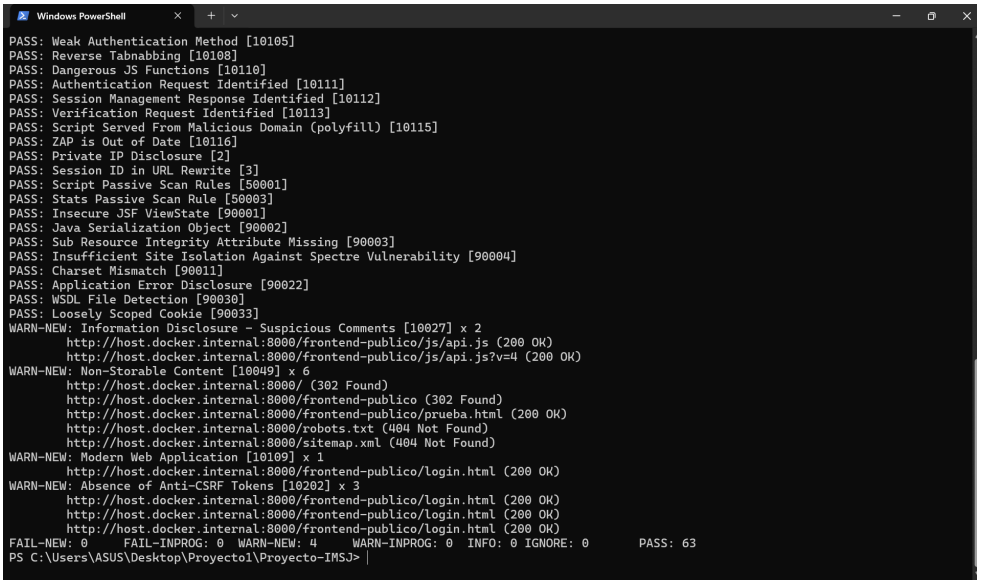
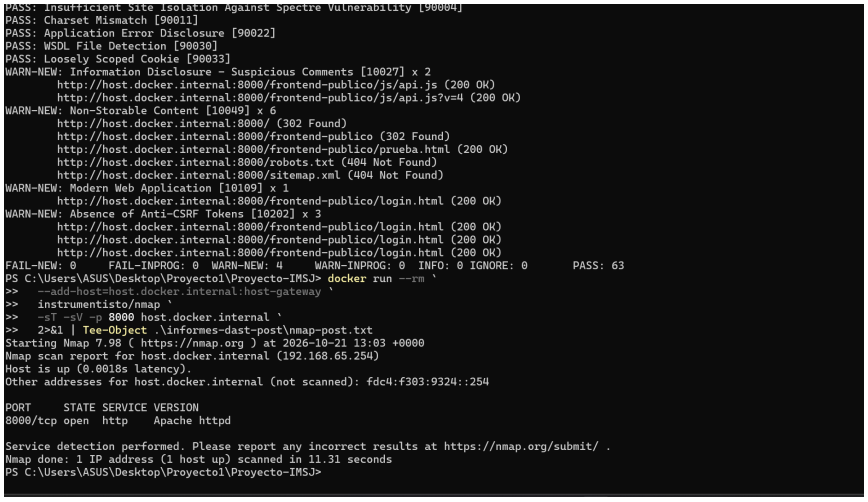


Figura 5. Nmap confirma el puerto 8000 y oculta la versión exacta de Apache.



Integridad de artefactos posteriores

Artefacto	SHA-256
zap-report-post.json	316C4AE7D043A11A9F6BC21A3FC4A3A12AFA12E7F54FB13E23DFA16BDCD54F30
zap-report-post.html	4FA956EEB6DB097F18BBEBB6FF6350B2ECC757A87D3DBCAD392A0C1D4B750E31
zap-post-terminal.txt	9831E979C6DDDDB785AB92357717E87FF56F2074397E8A7F270818CCA1764FB5
nmap-post.txt	11CEC12C79378F827037A061A73CFDAABE7BF80008E77A33A982C2C64B41D7F1